Case 02 · Decision log (ADR log): Private Exposure Registry

Companion to the architecture chapter. Each entry follows the ADR (Architecture Decision Record) format: context, decision, alternatives considered and rejected, and consequences.

How to read this log

When an architect decides that a wall is load-bearing, they write down why, so that whoever renovates later does not knock it down. An ADR does the same for software: a short record of one decision, what led to it, and what was given up. Records are never deleted. If a decision changes, a new record supersedes the old one.

One principle runs through every record in this system: nobody trusts anybody. Each decision asks what happens if one participant, a regulator, a server or a fund, misbehaves.

No.	Decision	Status
ADR-001	The log is the source of truth, not a database	Accepted
ADR-002	Separate paths for reports and for questions (CQRS)	Accepted
ADR-003	A durable queue for envelopes instead of direct sending	Accepted
ADR-004	Catalog or budget changes need three signatures	Accepted
ADR-005	One blind token per institution per period	Accepted
ADR-006	A threshold of five funds per cell, and differencing checks at design time	Accepted
ADR-007	Every total verified against commitments; binary search to find a tampering server	Accepted
ADR-008	Shares deleted after 90 days	Accepted

ADR-001: The log is the source of truth

- **Status:** Accepted
- **Components:** Transparency Log, Collector and Verifier, Query Gate, Spot Audit

Context

Every claim in the registry, who reported, what was opened, which question was asked, must be checkable by someone who trusts none of the regulators.

Decision

A Merkle-tree transparency log is the source of truth. Every component writes to it before confirming an action, and anyone can read it. A root signed by all three regulators is published daily. The regulator's entire state can be rebuilt from the log alone.

Alternatives considered and rejected

- **A regular database at one regulator:** rejected because whoever holds it can quietly rewrite history, and the other two must trust them.

Consequences

- **Positive:** history cannot be changed without detection, and every claim is checkable.
- **Negative:** the log must always be available, so it is replicated. Changing the shape of an event already written is hard.

ADR-002: Separate paths for reports and for questions

- **Status:** Accepted
- **Components:** Leader, Collector and Verifier, Query Gate, Reports

Context

Regulators ask questions and funds report. If both travel the same path, there is always a risk that a question touches a single report.

Decision

Two separate paths (CQRS): the write path receives reports and aggregates them into batches. The read path answers only from verified totals of closed batches.

Alternatives considered and rejected

- **One model for writing and reading:** simpler. Rejected because the separation is part of the security: there is no path on which a regulator's question touches a single report.

Consequences

- **Positive:** a structure in which leaking through a question is simply not possible.
- **Negative:** an answer is available only after a batch has closed and been verified.

ADR-003: A durable queue for envelopes

- **Status:** Accepted
- **Components:** Leader, Helper Servers, Participant App

Context

Each report needs three envelopes to reach three servers in three countries. One of them will sometimes be down, and when all three shares are needed, a lost envelope is a lost report.

Decision

The leader stores the report and each helper's envelope in the same transaction (transactional outbox) and delivers from the queue until the helper acknowledges. The leader cannot open the helpers' envelopes, even while holding them.

Alternatives considered and rejected

- **Funds sending directly to every helper:** rejected because every helper outage would lose reports, and funds would have to manage retries themselves.

Consequences

- **Positive:** no report is lost when a helper goes down. The report is late, but complete.
- **Negative:** delivery is eventual, not immediate, and duplicates are possible, so helpers must deduplicate by report ID.

ADR-004: Catalog or budget changes need three signatures

- **Status:** Accepted
- **Components:** Query Gate, Transparency Log

Context

The catalog decides which questions may be asked, and the privacy budget decides how many. Whoever changes them can, on purpose or by mistake, expose a fund.

Decision

Any change to the catalog or budget takes effect only with signatures from all three regulators, and is recorded in the log.

Alternatives considered and rejected

- **One regulator approves:** fast. Rejected because a single regulator could then add a question designed to expose a participant, or quietly raise the budget.

Consequences

- **Positive:** no regulator can change the rules alone.
- **Negative:** changes are slow. If one regulator does not respond, nothing changes. This is intended.

ADR-005: One blind token per institution per period

- **Status:** Accepted
- **Components:** Identity Service, Participant App, Leader

Context

The five-fund threshold only means something if every fund is a real institution. Without identification, an attacker could register four empty funds, open a cell holding a single fund, and subtract themselves.

Decision

The identity service checks the LEI against the global registry and the list of supervised institutions, and issues one blind token per institution per period. The token is blinded before signing, so the service cannot link it to a report.

Alternatives considered and rejected

- **Open identification on every report:** rejected because the servers would then know who reported what, and the whole split loses its point.
- **No identification at all:** rejected because of the fake-fund attack.

Consequences

- **Positive:** only real institutions are counted, and no server knows who they are.
- **Negative:** a dependency on an external registry. The substitute is the list of institutions the regulator already holds.

ADR-006: A threshold of five, and differencing checks at design time

- **Status:** Accepted
- **Components:** Query Gate

Context

Even an aggregate can expose a participant: in a cell with two funds, each can subtract itself and learn the other. And two close questions, such as "all sectors" and "all sectors except energy", can reveal a small sector through their difference.

Decision

A cell with fewer than five funds is never opened. Every new catalog question is automatically checked against every existing one, and a pair whose difference is a small cell is rejected before it is asked even once. Controlled noise is added to public answers.

Alternatives considered and rejected

- **Noise only, without a threshold:** rejected because in a very small cell the noise needed for protection destroys the answer.
- **Checking differences at publication time:** rejected because by then the first answer is already out.

Consequences

- **Positive:** the differencing attack is blocked at design time.
- **Negative:** some interesting questions go unanswered, and small sectors stay blocked.

ADR-007: Every total verified; binary search to find a tampering server

- **Status:** Accepted
- **Components:** Participant App, Transparency Log, Collector and Verifier

Context

A compromised server can change its partial total, and the addition still works: the result is wrong but looks plausible.

Decision

Each fund locks its data in a homomorphic commitment and records it in the log before splitting. The collector checks that the sum of shares equals the sum of commitments. If not, it runs a binary search over halves of the batch until the tampering server is identified, with proof in the log.

Alternatives considered and rejected

- **Trusting the servers:** rejected because the system is built on the assumption that nobody trusts anybody.
- **Heavy proofs from every server on every operation:** rejected on cost. The aggregate check is cheap, and the search runs only when something is wrong.

Consequences

- **Positive:** a wrong total is never opened to any question, and the culprit is identified.
- **Negative:** commitments make each report larger, and the search delays the report when there is a fault.

ADR-008: Shares deleted after 90 days

- **Status:** Accepted
- **Components:** Server stores

Context

As long as the shares are kept on all three servers, a future breach of all three together could reconstruct old reports.

Decision

Each server deletes its shares 90 days after the batch has closed and been verified. Verified totals stay with the regulator, the log is kept forever, and each fund's secrets stay only with the fund, for future audits.

Alternatives considered and rejected

- **Keeping them forever:** rejected because of the accumulating risk.
- **Deleting immediately:** rejected because time is needed to investigate faults and run the spot audit.

Consequences

- **Positive:** the exposure window is limited in time.
- **Negative:** after 90 days a new question cannot be computed over old data. Only what was already opened remains.